

Identity & Access Review Checklist

Evaluate MFA coverage, privileged access, conditional access, and lifecycle controls in one pass. Designed to be run quarterly as a standing identity hygiene review.

MFA Coverage

- ☐ MFA is enforced for 100% of employee accounts, not just administrators.
- ☐ Phishing-resistant MFA (FIDO2/passkeys) is used for privileged and executive accounts.
- ☐ Legacy authentication protocols that bypass MFA (IMAP, POP3, basic auth) are disabled.
- ☐ Break-glass emergency access accounts are documented, monitored, and tightly controlled.
- ☐ MFA enrollment is monitored, with gaps remediated within a defined SLA.
- ☐ Service accounts and API integrations use certificate- or key-based auth where MFA doesn't apply.
- ☐ MFA fatigue attack protections (number matching, rate limiting) are enabled.

Privileged Access

- ☐ Standing administrative access is eliminated in favor of just-in-time elevation.
- ☐ A privileged access management (PAM) solution vaults and rotates admin credentials.
- ☐ All privileged sessions are logged and, where feasible, recorded.
- ☐ The number of Global/Domain Admin-equivalent accounts is minimized and documented.
- ☐ Privileged accounts are separate from standard user accounts — no daily-use admin accounts.
- ☐ Third-party/vendor privileged access is time-boxed and reviewed after each use.
- ☐ Privileged access reviews are conducted at least quarterly with sign-off from a named owner.

Conditional Access

- ☐ Access policies incorporate device compliance/health signals, not just credentials.
- ☐ High-risk sign-ins (impossible travel, anonymized IPs, leaked credentials) trigger step-up auth or block.
- ☐ Access to sensitive applications is restricted to managed devices where feasible.
- ☐ Location- or network-based conditions are applied for the most sensitive systems.
- ☐ Session lifetime and re-authentication intervals are defined based on risk, not left at defaults.
- ☐ Legacy or unsupported browsers and clients are blocked from accessing sensitive resources.
- ☐ Conditional access policies are tested in report-only mode before enforcement.

Lifecycle Management

- ☐ A documented joiner-mover-leaver process exists and is followed consistently.
- ☐ Access is provisioned based on role/group membership, not manual one-off grants.
- ☐ Terminated employee access is revoked within a defined SLA (ideally same-day).
- ☐ Access changes triggered by role changes (movers) are reviewed, not just additive.
- ☐ Orphaned accounts (no active owner, no recent login) are identified and disabled on a recurring cadence.
- ☐ Contractor and temporary access has defined expiration dates enforced automatically.
- ☐ An access certification campaign is run at least annually across all critical systems.